QUESTION 8: MITRE ATT&CK TECHNIQUES

DG Interns Hub Cybersecurity Internship – Week 5 Submission

Student Name: Gunjan **Track:** SOC Analyst Tier 1 **Topic:** Analysis of Key MITRE ATT&CK Adversary Techniques

The **MITRE ATT&CK Framework** is a curated knowledge base detailing real-world adversary tactics, techniques, and procedures (TTPs). Below is a complete operational analysis of five core techniques every L1 SOC analyst must understand during alert triage.

T1110 – Brute Force

TACTIC: CREDENTIAL ACCESS (TA0006)

Explanation: Adversaries systematically attempt multiple username and password combinations to gain unauthorized access to accounts.

How Attackers Use It: Automated scripts run wordlists or spray common passwords across exposed VPN, SSH, or RDP portals to compromise weak accounts without triggering account lockouts.

Detection & Logs: Windows Event ID **4625** (Failed Logon), Linux `/var/log/auth.log`.

L1 Investigation Steps: 1. Check IP reputation on AbuseIPDB. 2. Verify if failure count is followed by Event 4624 (Successful Logon). 3. If successful, initiate emergency account lock and notify L2.

T1136 – Create Account

TACTIC: PERSISTENCE (TA0003)

Explanation: Adversaries create secondary local or domain user accounts to maintain access even if their initial entry point is patched.

How Attackers Use It: After obtaining administrative access, attackers run command-line utilities (e.g., `net user`) to establish hidden backdoor admin accounts.

Detection & Logs: Windows Event ID **4720** (User Account Created), Event ID **4728** (Member added to security group).

L1 Investigation Steps: 1. Identify creator username from Event 4720. 2. Verify with IT ticketing if account creation was an authorized task. 3. If unauthorized, disable new account and escalate to L2.

T1059.001 – PowerShell

TACTIC: EXECUTION (TA0007)

Explanation: Adversaries abuse PowerShell, a powerful built-in Windows shell, to execute malicious scripts and manipulate core OS settings ("Living off the Land").

How Attackers Use It: Running hidden, Base64-encoded command lines (`powershell.exe -enc ...`) to download secondary payloads directly into memory, bypassing disk-based antivirus.

Detection & Logs: Windows Script Block Logging Event ID **4104**, Sysmon Event ID **1** (Process Creation).

L1 Investigation Steps: 1. Extract command line from SIEM logs. 2. Decode Base64 payloads using CyberChef. 3. Check parent process (e.g., `winword.exe` launching `powershell.exe`) and isolate host if malicious.

T1046 – Network Service Scanning

TACTIC: DISCOVERY (TA0007)

Explanation: Attackers probe network IP ranges and ports to identify active hosts, open services, and vulnerable applications.

How Attackers Use It: Running automated network scanning tools like Nmap or Masscan to locate open SMB (445), RDP (3389), or SSH (22) services across internal subnets.

Detection & Logs: Firewall traffic logs, Suricata/Snort IDS alerts, EDR network connection events.

L1 Investigation Steps: 1. Identify scanning source IP. 2. Confirm if IP belongs to an authorized internal IT scanner. 3. If unauthorized internal host, isolate computer and flag for lateral movement investigation.

T1566 – Phishing

TACTIC: INITIAL ACCESS (TA0001)

Explanation: Adversaries send deceptive electronic communications to trick users into revealing credentials or downloading malicious attachments.

How Attackers Use It: Sending spoofed emails with malicious Office macros or links pointing to fake credential harvesting login pages.

Detection & Logs: Secure Email Gateway (SEG) logs, Exchange/Office 365 Audit Logs, EDR web access alerts.

L1 Investigation Steps: 1. Check email SPF/DKIM headers. 2. Scan attachments/URLs on VirusTotal. 3. If malicious, search mail logs to purge message across all inboxes and reset victim passwords.

LEARNING REFERENCES

- MITRE ATT&CK Enterprise Matrix: **https://attack.mitre.org/**
- Microsoft Security Audit Log Reference: **https://learn.microsoft.com/**